

Mr. Robot CTF - Walkthrough

Target: Mr. Robot (VulnHub)

Goal: Capture 3 Flags & Obtain Root Access

I. Reconnaissance & Enumeration

Network Discovery

The objective was to identify the target machine within the isolated lab environment. Using the `ip a` command, I identified my attacking machine and then scanned the local subnet to find the target.

- **Attacker Machine:** [KALI_VM_IP]
- **Target Machine:** [TARGET_IP] (Identified as the host at .133)

Service Scanning

I performed an aggressive service scan to identify open ports and software versions: `sudo nmap -sV -sC [TARGET_IP]`

Key Finding: Port 80 (HTTP) was open, hosting a web server.

Web Discovery

Visiting the web interface at `http://[TARGET_IP]` revealed a specialized interface. To find hidden entry points, I used **Gobuster**: `gobuster dir -u http://[TARGET_IP] -w /usr/share/wordlists/dirb/common.txt`

Interesting Paths Found:

- `/robots.txt`: Often contains clues for search engines.
 - `/wp-login.php`: Indicates the site is running WordPress.
-

II. Initial Access (Flag #1 & #2)

Flag #1: The Robots.txt Lead

By navigating to `http://[TARGET_IP]/robots.txt`, I discovered two files: `fsociety.dic` and `key-1-of-3.txt`. Accessing the `.txt` file provided the first flag.

Flag #2: WordPress Compromise

The `fsociety.dic` file served as a custom dictionary. After sorting and cleaning the list, I used it to brute-force the WordPress login for the user **Elliot**.

1. **Web Shell Injection:** Once logged into WordPress, I edited the `404_Template` and replaced the code with a **PHP Reverse Shell**.
 2. **Gaining a Shell:** I set up a listener on my Kali machine: `nc -lvnp 1234`. By triggering the 404 error on the site, I received a connection.
 3. **Privilege Switch:** Inside the `/home/robot` directory, I found a password hash in `password.raw-md5`. I cracked the hash using CrackStation to gain access to the **Robot** user account and read the second flag.
-

III. Privilege Escalation (Flag #3)

SUID Enumeration

To reach the final goal, I needed to escalate to the **Root** user. I searched for files with the SUID bit set: `find / -perm -u=s -type f 2>/dev/null`

The "Nmap" Exploit

The enumeration revealed that a legacy version of `nmap` was configured with SUID permissions. This version included an **Interactive Mode**, which can be exploited to escape to a shell.

1. **Enter Interactive Mode:** `nmap --interactive`
2. **Escape to Root:** `!sh`

Final Result: The prompt changed to `#`, confirming **Root** access. I navigated to the `/root` directory to capture the final flag.